PRACTICAL 3: POST-INCIDENT ANALYSIS

Objective
To perform post-incident analysis for a simulated phishing attack by conducting Root Cause Analysis (RCA), creating a Fishbone Diagram, and calculating SOC performance metrics such as Mean Time to Detect (MTTD) and Mean Time to Respond (MTTR).

Tools Used
- Google Sheets
- draw.io
- Microsoft Word / Google Docs

Incident Scenario
A phishing email was delivered to a user and the malicious link was clicked, leading to a potential security incident. Post-incident analysis was performed to identify the root causes, contributing factors, and response efficiency.

1. Root Cause Analysis (5 Whys Method)
The 5 Whys technique was used to identify the fundamental cause of the phishing incident.

Question	Answer
Why was the phishing email opened?	User clicked malicious link
Why was the malicious link clicked?	The email appeared legitimate
Why did it appear legitimate?	Weak email filtering allowed spoofed email
Why was filtering weak?	Security rules were outdated
Why were rules outdated?	No regular review of email security policies

---

Analysis
The investigation showed that the root cause was not only user action but also weak security controls and lack of regular policy reviews. This indicates both technical and process gaps within the organization.

2. Fishbone Diagram (Cause-and-Effect Analysis)
A Fishbone Diagram (Ishikwa Diagram) was created to identify the major contributing factors of the phishing incident.
Main Cause Categories
People
- Lack of awareness
- User clicked suspicious email

Process
- No email review policy
- Delayed incident escalation

Technology
- Weak spam filtering
- No Multi-Factor Authentication (MFA)

Policy

- No phishing response checklist
- Poor access control review

Training

- No phishing awareness training
- No phishing simulation exercises

Figure 1: Fishbone Diagram for Phishing Incident
The diagram visually represents how multiple organizational weaknesses contributed to the phishing attack.

3. SOC Metrics Calculation
Mean Time to Detect (MTTD)
Time taken to detect the phishing attack:
MTTD = 2 Hours

Mean Time to Respond (MTTR)
Time taken to contain and respond to the incident:
MTTR = 4 Hours

Metrics Table

Metric	Value
Mean Time to Detect (MTTD)	2 Hours
Mean Time to Respond (MTTR)	4 Hours

Metrics Interpretation
The organization detected the phishing attack within 2 hours and completed containment and response within 4 hours. Lower MTTD and MTTR indicate stronger SOC efficiency and faster incident response capability.

4. 50-Word Summary
The phishing incident was analyzed using Root Cause Analysis and a Fishbone Diagram. The main causes were weak email filtering, lack of user awareness, and poor security policies. MTTD was 2 hours and MTTR was 4 hours, showing the efficiency of incident detection and response.

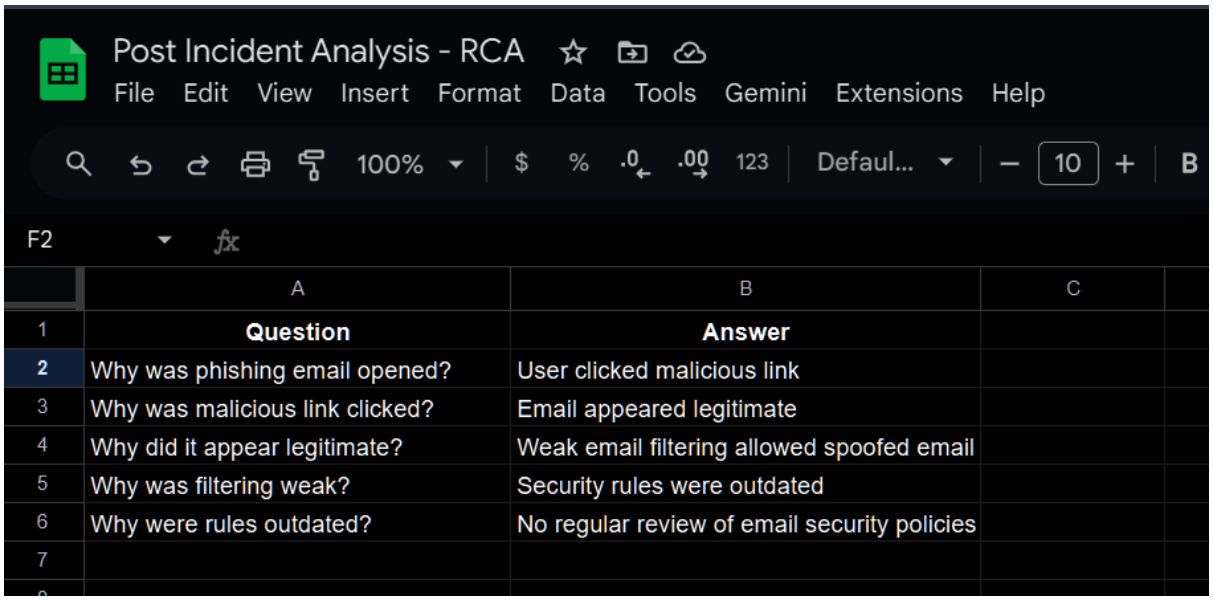
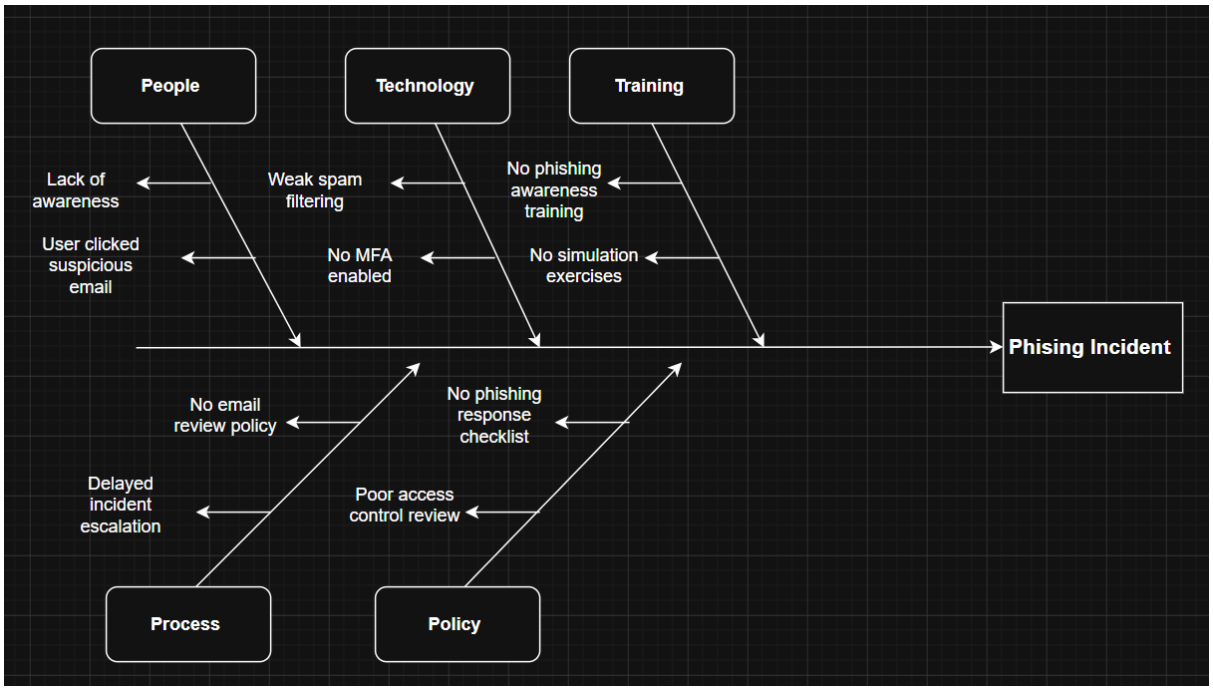
Lessons Learned

- Improve email filtering and anti-phishing controls
- Conduct regular phishing awareness training
- Enable Multi-Factor Authentication (MFA)
- Review and update email security policies regularly
- Establish formal phishing incident response procedures

Conclusion

The post-incident analysis successfully identified the root causes and contributing factors of the phishing attack. Using the 5 Whys method, Fishbone Diagram, and SOC metrics helped improve understanding of organizational weaknesses and provided recommendations to strengthen future incident prevention and response.

Screenshots



	A	B	C
1	**Question**	**Answer**	
2	Why was phishing email opened?	User clicked malicious link	
3	Why was malicious link clicked?	Email appeared legitimate	
4	Why did it appear legitimate?	Weak email filtering allowed spoofed email	
5	Why was filtering weak?	Security rules were outdated	
6	Why were rules outdated?	No regular review of email security policies	
7